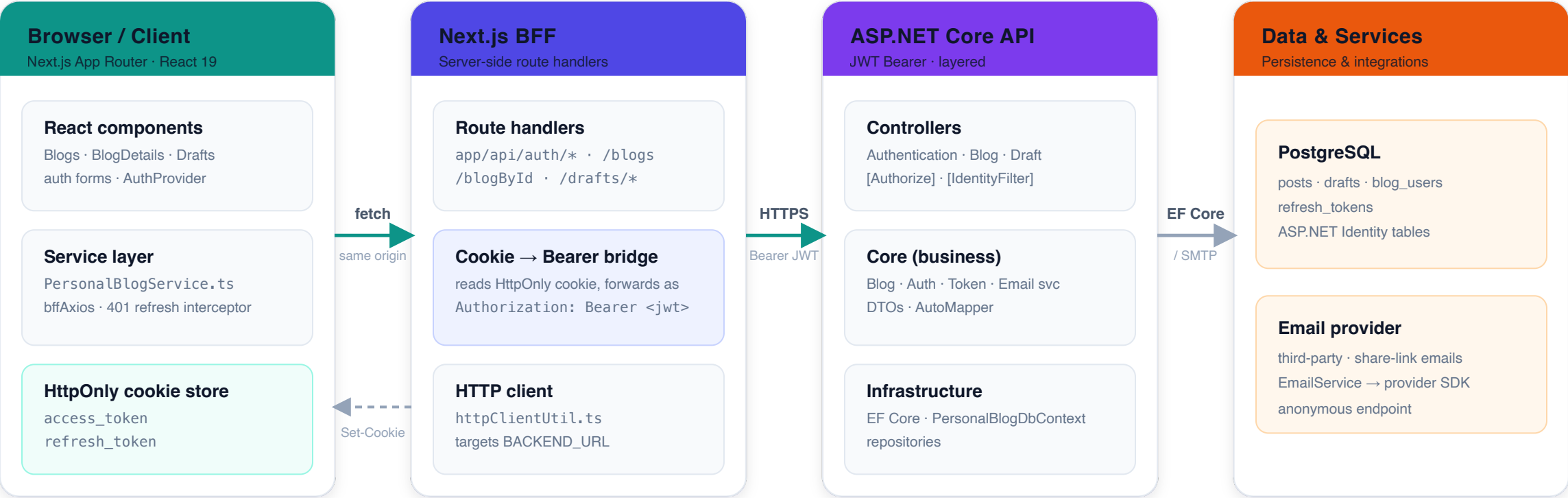


Personal Blog — System Architecture

Request flow from the browser through the Next.js BFF to the ASP.NET Core API and its data stores.

● request

---- Set-Cookie / data



- 1

Login
POST /api/auth/login validates credentials, issues JWT + refresh token; BFF sets them as HttpOnly cookies.
- 2

Authenticated request
Browser sends cookie to the BFF (same origin); the BFF forwards the token as Authorization: Bearer <jwt>.
- 3

Validation
API validates issuer / audience / lifetime / signature. [IdentityFilter] also checks sub claim == {id} route param.
- 4

Refresh on 401
bffAxios interceptor calls POST /api/auth/refresh once, rotates the refresh token, and replays the request.

Note: the .NET API reads the JWT from the Authorization header only — the cookie→Bearer translation happens in the Next.js BFF.